



Arquitectura de Seguridad en APIs

Autenticación y Autorización en la Capa 7 (API Keys, OAuth 2.0 y JWT)

La columna vertebral de la arquitectura distribuida



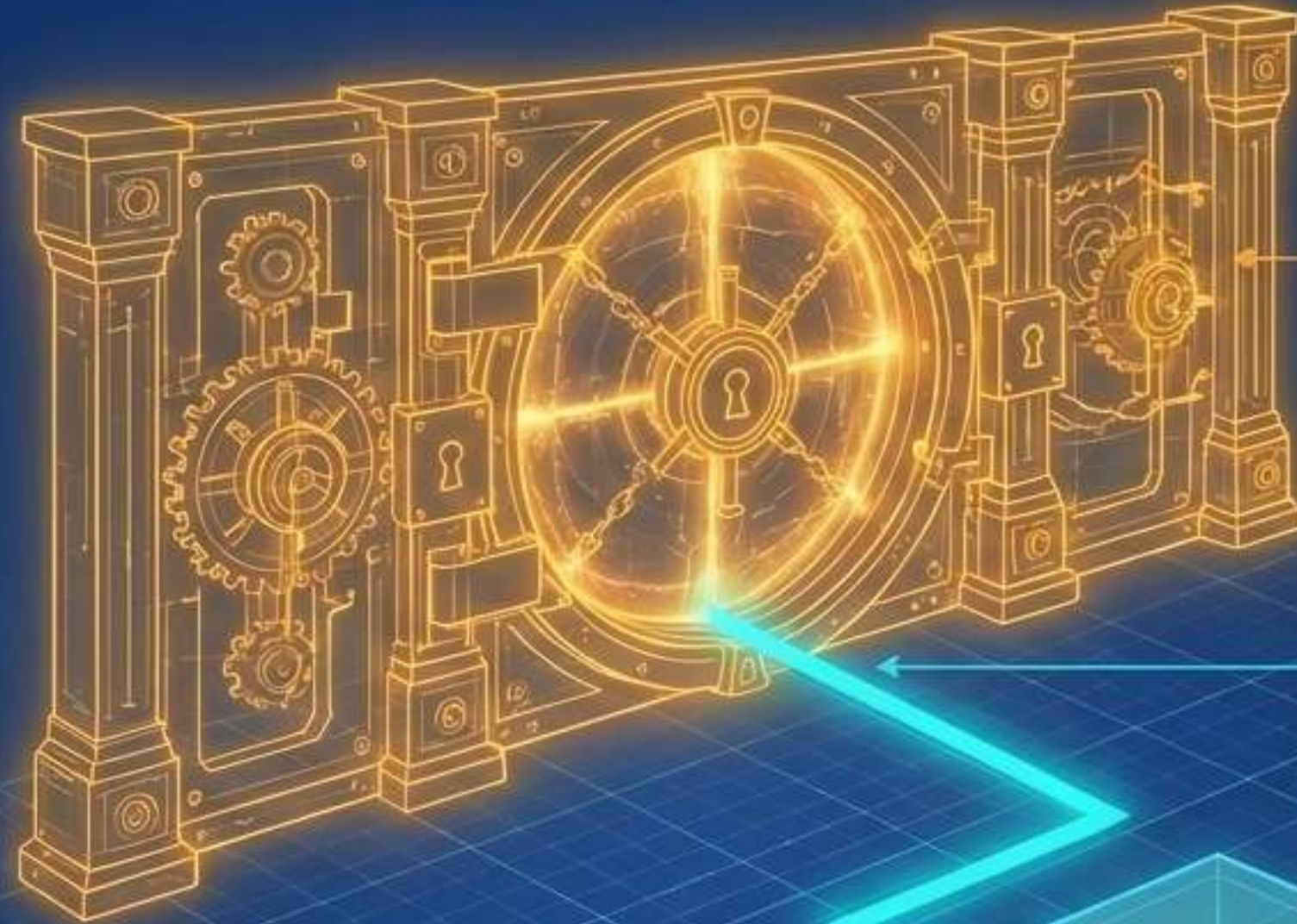
Las APIs facilitan la integración de sistemas heterogéneos y la innovación abierta. Su viabilidad depende fundamentalmente de la seguridad.

La Anatomía Completa de una API



Comprender cada capa es esencial para construir y mantener APIs robustas, seguras y escalables en una arquitectura distribuida.

El perímetro de Seguridad



Controlan quién puede acceder y qué puede hacer.

El **vector de entrega físico** ocurre en la **Capa 4** (Parámetros/Headers), donde viajan los metadatos de autenticación.

**Capa 4:
Headers**


1. API Keys
Identificadores
únicos


2. OAuth 2.0
Autorización
delegada

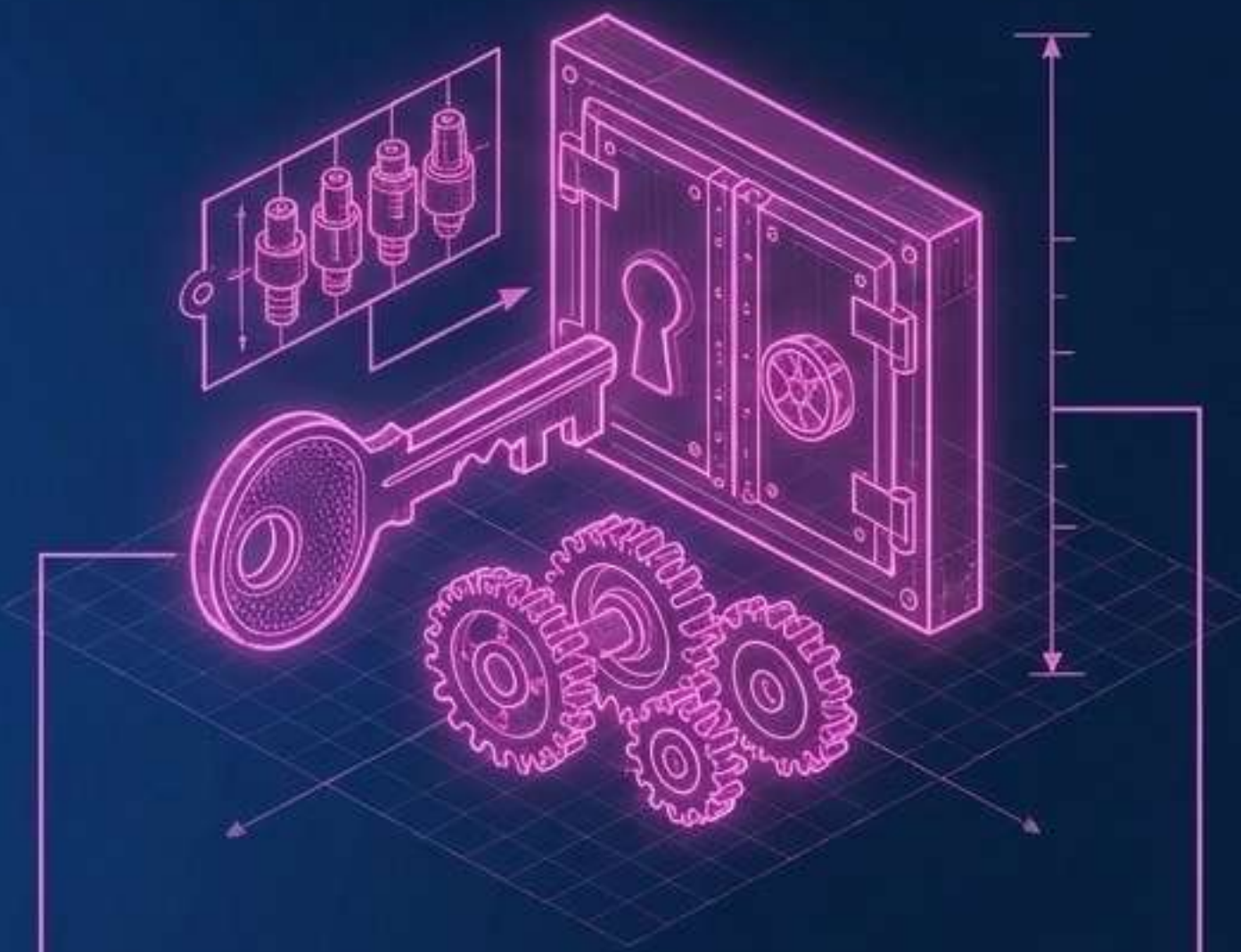

3. JWT
Tokens
firmados

Diferenciando AuthN de AuthZ



Autenticación (AuthN)

Responde a la pregunta: ¿Quién eres?.
Valida la identidad del cliente que realiza la petición.



Autorización (AuthZ)

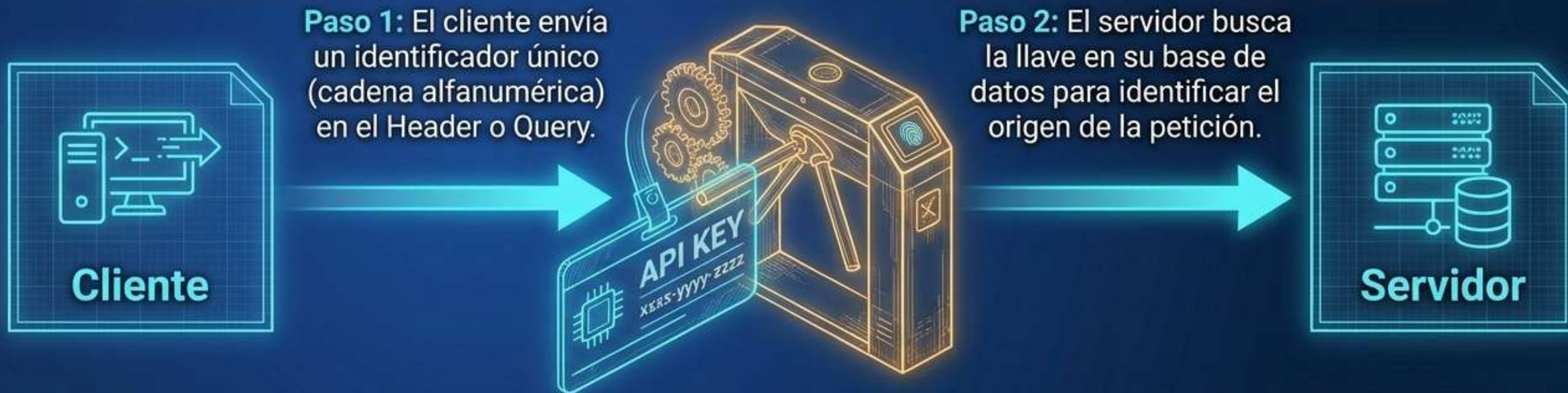
Responde a la pregunta: ¿Qué puedes hacer?.
Valida los permisos y el nivel de acceso del cliente autenticado sobre recursos específicos.

El Vehículo de Entrega: Encabezados HTTP



Control de Acceso: API Keys

Metáfora Arquitectónica: La Tarjeta de Identificación (ID Badge)



Simple de implementar. Útil para identificar aplicaciones (no usuarios). No caducan automáticamente, lo que requiere estrategias de rotación para mitigar riesgos.

Autorización Delegada: OAuth 2.0

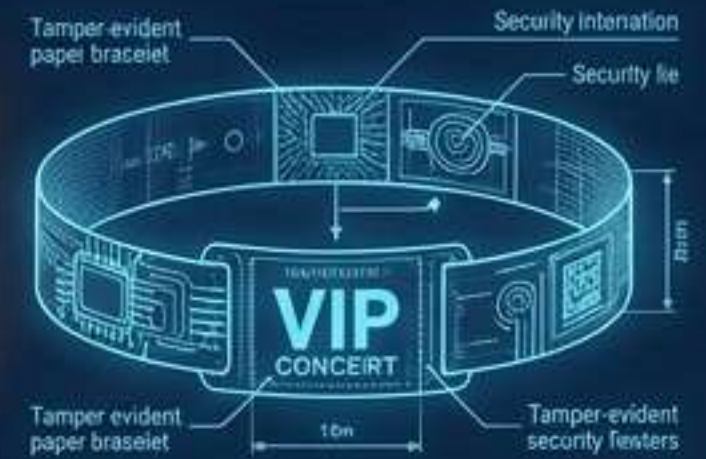
Metáfora Arquitectónica: La Llave de Valet Parking
(Permite estacionar el auto, pero no abrir el maletero)



Key Takeaway: Desacopla la autenticación del acceso a la API.
El cliente nunca ve la contraseña del usuario.

Tokens Autónomos: JWT (JSON Web Token)

Metáfora Arquitectónica: La Pulsera VIP (Contiene toda la información necesaria y evidencia de manipulación)



Algoritmo de firma
y tipo de token.

Datos de identidad y permisos
(validan identidad y permisos).

Firma criptográfica para garantizar
que el token no ha sido alterado.

Key Takeaway: Autenticación sin estado (Stateless). El servidor valida matemáticamente la firma sin consultar una base de datos.

Arquitectura en la Práctica: API de PayPal



Endpoint:

api-m.paypal.com/v2/payments/...

Objetivo:

Autorizar y capturar pagos de forma segura.

Para realizar llamadas a la API REST de PayPal, el esquema de autenticación requiere:

Opción A (Token Portador):

`Authorization: Bearer <Access-Token>`

Opción B (Credenciales Básicas):

`Authorization: Basic <client_id>:<secret>`

Matriz de Decisión Arquitectónica

Mecanismo	Propósito Principal	Estado (Stateful/Stateless)	Complejidad de Implementación
API Keys	Autenticación de Apps	Stateful (requiere BD)	Baja
Basic Auth	Autenticación simple	Stateless (pero acoplado a credenciales)	Baja
OAuth 2.0	Autorización Delegada a terceros	Centralizado en Auth Server	Alta
JWT	Identidad y permisos portables	Stateless (Autocontenido)	Media

La elección del patrón dependerá del ecosistema (interno vs. público) y el nivel de desacoplamiento requerido.